شركة قيروان لأنظمة المعلومات

سياسة حماية البيانات

برنامج الالتزام بالضوابط الأساسية للأمن السيبراني · مرحلة الحوكمة

رقم الوثيقة	QIS-POL-001
الإصدار	0.1 (مسودة)
التاريخ	5 نوفمبر 2026م
التصنيف	داخلي
أعدّها	نايف السالم، قائد الحوكمة والمخاطر والالتزام

دراسة حالة افتراضية. شركة قيروان لأنظمة المعلومات (QIS) وموظفوها وعملاؤها جهات وشخصيات افتراضية أُعدّت لملف أعمال مهني، وأي تشابه مع جهة حقيقية غير مقصود. أما الجهات التنظيمية والأطر المذكورة فهي حقيقية.

لغة الوثيقة. تصدر هذه الوثيقة باللغتين العربية والإنجليزية، وفي حال وجود تعارض بين النصين يُعتمد النص العربي.

ضبط الوثيقة

الدور	المسمى الوظيفي	الاسم	الحالة
المالك	قائد الحوكمة والمخاطر والالتزام، مسؤول حماية البيانات الشخصية	نايف السالم	مكتمل
المراجِع	الرئيس التنفيذي للتقنية	ريم العتيبي	قيد الانتظار
المصادِق	اللجنة الإشرافية للأمن السيبراني	—	قيد الانتظار
المعتمِد	الرئيس التنفيذي	فيصل الحربي	قيد الانتظار

سجل الإصدارات

الإصدار	التاريخ	المُعِدّ	التغيير
0.1	5 نوفمبر 2026م	نايف السالم	المسودة الأولى للمراجعة

دورة المراجعة: سنوياً، أو عند تغيّر الأنظمة واللوائح ذات العلاقة أو خدمات الشركة أو بعد حادثة تمس البيانات.

مفتاح ألوان المؤشرات

تُرفق ببنود هذه السياسة مؤشرات أداء (KPIs) لقياس تطبيق الضوابط، ومؤشرات مخاطر (KRIs) للإنذار المبكر، وتُعرض حالتها بالألوان التالية.

اللون	الحالة	المعنى والإجراء المطلوب
أخضر	**ضمن الهدف**	المؤشر ضمن الحد المقبول، ويستمر الرصد الاعتيادي.
أصفر	**يحتاج إلى انتباه**	المؤشر يقترب من الحد الأعلى المقبول، ويتطلب متابعة وتصحيحاً خلال الفترة المحددة.
أحمر	**خطر أو عدم التزام**	المؤشر تجاوز العتبة الحرجة، ويتطلب تصعيداً فورياً للإدارة العليا وخطة معالجة عاجلة.

1. الغرض

تهدف هذه السياسة إلى حماية البيانات التي تملكها شركة قيروان لأنظمة المعلومات أو تعالجها نيابة عن عملائها الحكوميين، طوال دورة حياتها من الجمع والمعالجة والتخزين والنقل والمشاركة إلى الحفظ والإتلاف، بما يحقق السرية والسلامة والتوافر.

وتلتزم الشركة من خلالها بنظام حماية البيانات الشخصية ولائحته التنفيذية، والضوابط الأساسية للأمن السيبراني (ECC-2:2024)، وضوابط الأمن السيبراني للبيانات (DCC-1:2022)، ومعايير مكتب إدارة البيانات الوطنية، والالتزامات التعاقدية تجاه العملاء.

2. نطاق العمل

- جميع البيانات التي تملكها الشركة أو تعالجها للعملاء من (أ) إلى (و)، بأي شكل كانت: إلكترونية أو ورقية.

- جميع الأنظمة والأصول الواردة في نطاق البرنامج (QIS-PRF-001)، ومنها الأنظمة المستضافة وبوابة المواطنين.
- جميع الموظفين والمتعاقدين، والأطراف الخارجية التي تصل إلى البيانات، ومنها مزوّد الخدمات السحابية.

3. التعريفات

المصطلح	التعريف في هذه السياسة
البيانات الشخصية	كل بيان يمكن من خلاله معرفة الفرد أو تمييزه، كبيانات المواطنين في بوابة العميل (أ) وسجلات الطلاب لدى العميل (ج).
جهة التحكم	الجهة التي تحدد غرض معالجة البيانات الشخصية ووسيلتها. وهي العميل الحكومي في البيانات التي تعالجها الشركة نيابة عنه.
جهة المعالجة	الجهة التي تعالج البيانات لصالح جهة التحكم ونيابة عنها. وهي الشركة في الخدمات المقدمة لعملائها.
مستويات التصنيف	سري للغاية، وسري، ومقيد، وعام، وفق سياسة تصنيف البيانات الوطنية. وتطبق الشركة على بياناتها الداخلية التصنيف المحدد في QIS-DCL-001.
تقنيع البيانات	استبدال قيم البيانات الحساسة بقيم غير حقيقية تحافظ على شكلها، لاستخدامها في التطوير والاختبار.
حادثة البيانات	أي وصول أو كشف أو تعديل أو فقدان غير مصرح به للبيانات، فعلياً كان أو مشتبهاً به.

4. بنود السياسة

4.1 تصنيف البيانات والتعامل معها

1. تُصنَّف بيانات العملاء وفق تصنيف العميل نفسه، وتُصنَّف بيانات الشركة وفق QIS-DCL-001، ولا يُعامَل أي نظام يحتفظ ببيانات مقيدة أو أعلى قبل تحديد تصنيفها.

2. تُطبَّق قواعد التعامل التالية بحسب مستوى التصنيف:

المستوى	التخزين	النقل	المشاركة	الإتلاف
سري للغاية وسري	داخل المملكة، مشفّر، في أنظمة معزولة بإذن العميل	مشفّر، وبموافقة العميل الكتابية	ممنوعة إلا بموافقة كتابية من جهة التحكم	إتلاف آمن مع شهادة إتلاف
مقيد	داخل المملكة، مشفّر أثناء التخزين	مشفّر دائماً	لمن يحتاجها لأداء عمله وبموجب عقد	إتلاف آمن موثق
عام	دون قيود خاصة	دون قيود خاصة	مسموحة	حذف اعتيادي

مؤشرات الأداء (KPIs)

الرمز	المؤشر	المستهدف	التكرار
KPI-01	نسبة الأنظمة المستضافة التي حُدِّد تصنيف بياناتها ووُثِّق	100%	ربع سنوي

مؤشرات المخاطر (KRIs)

الرمز	المؤشر	العتبة	التكرار
KRI-01	عدد الأنظمة التي تحتفظ ببيانات مقيدة أو أعلى دون تصنيف موثق	أخضر: 0 أصفر: 1 أحمر: 2 فأكثر	ربع سنوي

4.2 المعالجة وفق تعليمات العميل

1. تعالج الشركة بيانات العملاء وفق العقد والتعليمات الموثقة من جهة التحكم فقط، ولا تستخدمها لأي غرض آخر.

2. يتضمن كل عقد مع عميل بنوداً لمعالجة البيانات تحدد الغرض والنطاق ومدة الحفظ وموقع المعالجة والتزامات الإبلاغ والإعادة والإتلاف عند انتهاء العقد.

3. لا تستعين الشركة بطرف آخر لمعالجة بيانات العميل إلا بموافقته الكتابية المسبقة.

مؤشرات الأداء (KPIs)

الرمز	المؤشر	المستهدف	التكرار
KPI-02	نسبة عقود العملاء التي تتضمن بنود معالجة البيانات موقعة	100%	ربع سنوي

مؤشرات المخاطر (KRIs)

الرمز	المؤشر	العتبة	التكرار
KRI-02	عدد عمليات المعالجة أو الاستعانة بأطراف أخرى دون تعليمات أو موافقة موثقة من العميل	أخضر: 0 أحمر: 1 فأكثر	ربع سنوي

4.3 البيانات الشخصية

1. تقتصر المعالجة على الحد الأدنى من البيانات اللازم للغرض المحدد، ولا تُحفظ البيانات أطول من المدة المتفق عليها.

2. تحتفظ الشركة بسجل لأنشطة معالجة البيانات الشخصية لكل عميل.

3. تُحال طلبات أصحاب البيانات التي تصل إلى الشركة إلى جهة التحكم خلال يومي عمل، وتساعدها الشركة على تلبيتها في المدد النظامية.

4. يُجرى تقييم لأثر حماية البيانات قبل أي تغيير جوهري في بوابة المواطنين أو أي نظام يعالج بيانات شخصية.

مؤشرات الأداء (KPIs)

الرمز	المؤشر	المستهدف	التكرار
KPI-03	نسبة طلبات أصحاب البيانات المحالة إلى جهة التحكم خلال يومي عمل	100%	شهري

مؤشرات المخاطر (KRIs)

الرمز	المؤشر	العتبة	التكرار
KRI-03	عدد التغييرات الجوهرية على أنظمة البيانات الشخصية دون تقييم أثر	أخضر: 0 أحمر: 1 فأكثر	ربع سنوي

4.4 التشفير

1. تُشفَّر البيانات أثناء النقل عبر الشبكات باستخدام TLS 1.2 أو أحدث.

2. تُشفَّر البيانات المقيدة وما فوقها أثناء التخزين، وتُدار مفاتيح التشفير وفق معايير التشفير الوطنية، وتُحفظ بمعزل عن البيانات.

مؤشرات الأداء (KPIs)

الرمز	المؤشر	المستهدف	التكرار
KPI-04	نسبة قواعد البيانات المستضافة المشفرة أثناء التخزين	100%	ربع سنوي

مؤشرات المخاطر (KRIs)

الرمز	المؤشر	العتبة	التكرار
KRI-04	عدد الأنظمة التي تنقل بيانات العملاء دون تشفير	أخضر: 0 أحمر: 1 فأكثر	شهري

4.5 الوصول إلى البيانات

1. يُمنح الوصول إلى بيانات العملاء وفق مبدأ الحاجة إلى المعرفة والحد الأدنى من الصلاحيات، وبحسابات فردية محمية بالتحقق متعدد العوامل.

2. يُمنع استخدام الحسابات المشتركة للوصول إلى بيانات العملاء، وتُراجع الصلاحيات كل ربع سنة، وتُلغى فور انتهاء الحاجة إليها.

مؤشرات الأداء (KPIs)

الرمز	المؤشر	المستهدف	التكرار
KPI-05	نسبة مراجعات الصلاحيات المكتملة في موعدها	100%	ربع سنوي

مؤشرات المخاطر (KRIs)

الرمز	المؤشر	العتبة	التكرار
KRI-05	عدد الحسابات المشتركة أو العامة التي لها وصول إلى بيانات العملاء	أخضر: 0 أصفر: من 1 إلى 2 أحمر: 3 فأكثر	شهري

4.6 موقع البيانات والحوسبة السحابية

1. تُخزَّن بيانات العملاء وتُعالج داخل المملكة العربية السعودية فقط، ولدى مزوّد خدمات سحابية مرخّص من هيئة الاتصالات والفضاء والتقنية.

2. لا تُنقل البيانات خارج المملكة إلا بموافقة كتابية من جهة التحكم وبما يتوافق مع نظام حماية البيانات الشخصية ولوائحه.

مؤشرات المخاطر (KRIs)

الرمز	المؤشر	العتبة	التكرار
KRI-06	عدد مواقع تخزين بيانات العملاء خارج المملكة	أخضر: 0 أحمر: 1 فأكثر	ربع سنوي

4.7 الأطراف الخارجية والمتعاقدون

1. تُضمَّن متطلبات الأمن السيبراني وبنود السرية (NDA) في جميع العقود مع الأطراف الخارجية والمتعاقدين الذين يصلون إلى البيانات.
2. يُجرى التحقق الأمني المسبق للمتعاقدين قبل منحهم الوصول إلى بيانات العملاء أو أنظمتهم.
3. يلتزم الطرف الخارجي بإبلاغ الشركة فور وقوع أي حادثة قد تمس البيانات التي يعالجها.
4. عند انتهاء العلاقة التعاقدية تُعاد البيانات أو تُتلف، ويُقدَّم ما يثبت ذلك.

مؤشرات الأداء (KPIs)

الرمز	المؤشر	المستهدف	التكرار
KPI-07a	نسبة المتعاقدين الذين وقّعوا اتفاقية السرية واجتازوا التحقق المسبق	100%	شهري
KPI-07b	نسبة العلاقات المنتهية التي قُدِّم فيها دليل الإعادة أو الإتلاف	100%	ربع سنوي

مؤشرات المخاطر (KRIs)

الرمز	المؤشر	العتبة	التكرار
KRI-07	عدد الأطراف الخارجية أو المتعاقدين الذين يصلون إلى بيانات العملاء دون اتفاقية سرية سارية	أخضر: 0 أصفر: 1 أحمر: 2 فأكثر	شهري

4.8 البيانات في بيئات التطوير والاختبار

يُمنع استخدام بيانات شخصية حقيقية في بيئات التطوير والاختبار، وتُستخدم بدلاً منها بيانات مُقنَّعة أو مُصطنعة، ولا يُستثنى من ذلك إلا بموافقة كتابية من جهة التحكم ومن قائد الحوكمة والمخاطر والالتزام.

مؤشرات المخاطر (KRIs)

الرمز	المؤشر	العتبة	التكرار
KRI-08	عدد البيئات غير الإنتاجية التي تحتوي بيانات شخصية غير مُقنَّعة	أخضر: 0 أحمر: 1 فأكثر	ربع سنوي

4.9 الحفظ والإتلاف الآمن

1. تُحفظ البيانات للمدة المحددة في العقد أو النظام أيهما أطول، ثم تُتلف بطريقة آمنة لا تسمح باستعادتها.
2. تُتلف وسائط التخزين المستبعدة وفق إجراء موثق، وتُصدر شهادة إتلاف للبيانات المقيدة وما فوقها.

مؤشرات الأداء (KPIs)

الرمز	المؤشر	المستهدف	التكرار
KPI-09	نسبة عمليات الإتلاف الموثقة بشهادة إتلاف	100%	ربع سنوي

4.10 منع تسرب البيانات والإبلاغ عن الحوادث

1. تُطبَّق ضوابط منع تسرب البيانات على البريد الإلكتروني وخدمات التخزين السحابي.
2. يبلغ كل موظف أو متعاقد عن أي حادثة بيانات فعلية أو مشتبه بها فوراً وفق خطة الاستجابة للحوادث (QIS-IRP-001).

3. تُبلغ الشركة جهة التحكم المعنية خلال 24 ساعة من اكتشاف أي حادثة تمس بياناتها، لتتمكن من الوفاء بالتزامات الإبلاغ النظامية.

مؤشرات المخاطر (KRIs)

الرمز	المؤشر	العتبة	التكرار
KRI-10	عدد حوادث البيانات التي أُبلغ بها العميل بعد أكثر من 24 ساعة من اكتشافها	أخضر: 0 أحمر: 1 فأكثر	عند كل حادثة

4.11 التوعية

يكمل جميع الموظفين والمتعاقدين تدريباً على حماية البيانات عند الالتحاق وسنوياً بعد ذلك.

مؤشرات الأداء (KPIs)

الرمز	المؤشر	المستهدف	التكرار
KPI-11	نسبة الموظفين والمتعاقدين الذين أكملوا تدريب حماية البيانات السنوي	95% فأكثر	ربع سنوي

5. الأدوار والمسؤوليات

الدور	المسؤوليات
الرئيس التنفيذي	اعتماد السياسة، وتوفير الموارد اللازمة لتطبيقها، واعتماد الاستثناءات.
اللجنة الإشرافية للأمن السيبراني	المصادقة على السياسة، ومتابعة مؤشراتها ربع سنوياً، وتصعيد المؤشرات الحمراء.
قائد الحوكمة والمخاطر والالتزام (مسؤول حماية البيانات الشخصية)	ملكية السياسة وتحديثها، ومتابعة الالتزام بها، والتنسيق مع جهات التحكم، ورفع تقارير المؤشرات.
الرئيس التنفيذي للتقنية	تطبيق الضوابط التقنية: التشفير، والتحكم في الوصول، ومنع التسرب، وفصل البيئات.
رئيس تقديم الخدمات	تطبيق السياسة في الخدمات المُدارة، وضمان عدم استخدام الحسابات المشتركة لدى العملاء.
الرئيس التنفيذي للمالية	تضمين بنود معالجة البيانات والسرية في العقود، والتحقق المسبق من المتعاقدين، وإنهاء الوصول عند المغادرة.
المراجع المستقل	التحقق سنوياً من تطبيق السياسة ومدى فاعلية ضوابطها.
جميع الموظفين والمتعاقدين	الالتزام بالسياسة، والإبلاغ الفوري عن أي حادثة بيانات.

6. التحديث والمراجعة

يراجع قائد الحوكمة والمخاطر والالتزام هذه السياسة سنوياً على الأقل، أو عند حدوث تغييرات في الأنظمة واللوائح أو في خدمات الشركة أو بعد حادثة جوهرية تمس البيانات.

7. الالتزام بالسياسة

1. يتابع الرئيس التنفيذي الالتزام بهذه السياسة عبر تقارير المؤشرات المرفوعة إلى اللجنة الإشرافية.
2. يتحقق قائد الحوكمة والمخاطر والالتزام من الالتزام بالسياسة دورياً، ويوثق نتائج التحقق.
3. تتطلب أي حالة استثناء موافقة مسبقة موثقة من قائد الحوكمة والمخاطر والالتزام والرئيس التنفيذي، ويجب ألا تتعارض مع المتطلبات النظامية أو التعاقدية.
4. قد تؤدي مخالفة هذه السياسة إلى إجراءات تأديبية وفق اللوائح الداخلية للشركة.

8. المراجع

نوع المرجع	المرجع	الجهة
داخلي	QIS-PRF-001 ملف الشركة ونطاق البرنامج	الشركة
داخلي	QIS-DCL-001 تصنيف البيانات	الشركة
داخلي	QIS-RR-001 سجل المخاطر (R-01، R-05، R-14)	الشركة
داخلي	QIS-IRP-001 خطة الاستجابة للحوادث	الشركة
خارجي	نظام حماية البيانات الشخصية ولائحته التنفيذية	سدايا
خارجي	الضوابط الأساسية للأمن السيبراني (ECC-2:2024)	الهيئة الوطنية للأمن السيبراني
خارجي	ضوابط الأمن السيبراني للبيانات (DCC-1:2022)	الهيئة الوطنية للأمن السيبراني
خارجي	معايير إدارة البيانات وحوكمتها وحماية البيانات الشخصية	مكتب إدارة البيانات الوطنية

9. آلية التواصل

للاستفسار عن هذه السياسة أو الإبلاغ عن حادثة بيانات: مسؤول حماية البيانات الشخصية، عبر البريد الإلكتروني privacy@qis.example. أما الحوادث العاجلة فيُبلَّغ عنها فوراً وفق خطة الاستجابة للحوادث.